

##CRISCb- IT Risk Assessment Practices

###Objectives:

At the end of this episode, I will be able to understand:

1. Vulnerabilities are weaknesses or gaps in an organization's processes, technology and people
2. Threat actors use these to exploit or harm a business
3. Quite a few of these are pre-existing conditions in systems
4. Risk identification will need to locate and identify so that they can be solved or mitigated
5. Sources of Vulnerabilities - Networks
 - Typically due to misconfiguration or poor architecture
 - Open services are a potential attack vector
 - Non-hardened devices such as routers and switches can be compromised
 - Traffic interception is primarily the goal of an attacker
6. Sources of Vulnerabilities - Physical Access:
 - Physical access allows for:
 - Theft
 - Network access
 - Server room
 - Installing "skimmers"
 - Testing access control systems, locks, security guards, etc. is vital
7. Sources of Vulnerabilities - Applications/web services:
 - Web applications are one of the top attack vectors in IT
 - Most applications are written to support job roles vs. being secure
 - Application vulnerabilities include:
 - Logic flaws
 - Incorrect user access
 - Buffer overflows
 - Applications that contain sensitive information are placed in insecure areas
8. When it comes to Gap Analysis:
 - First you document the current state of vulnerabilities
 - Next you document the desired state that management requires
 - This allows risk practitioners to identify the gap and scope of the risk management process

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>